

Автоматизированный Аудит информационной безопасности (спецификация SCAR)

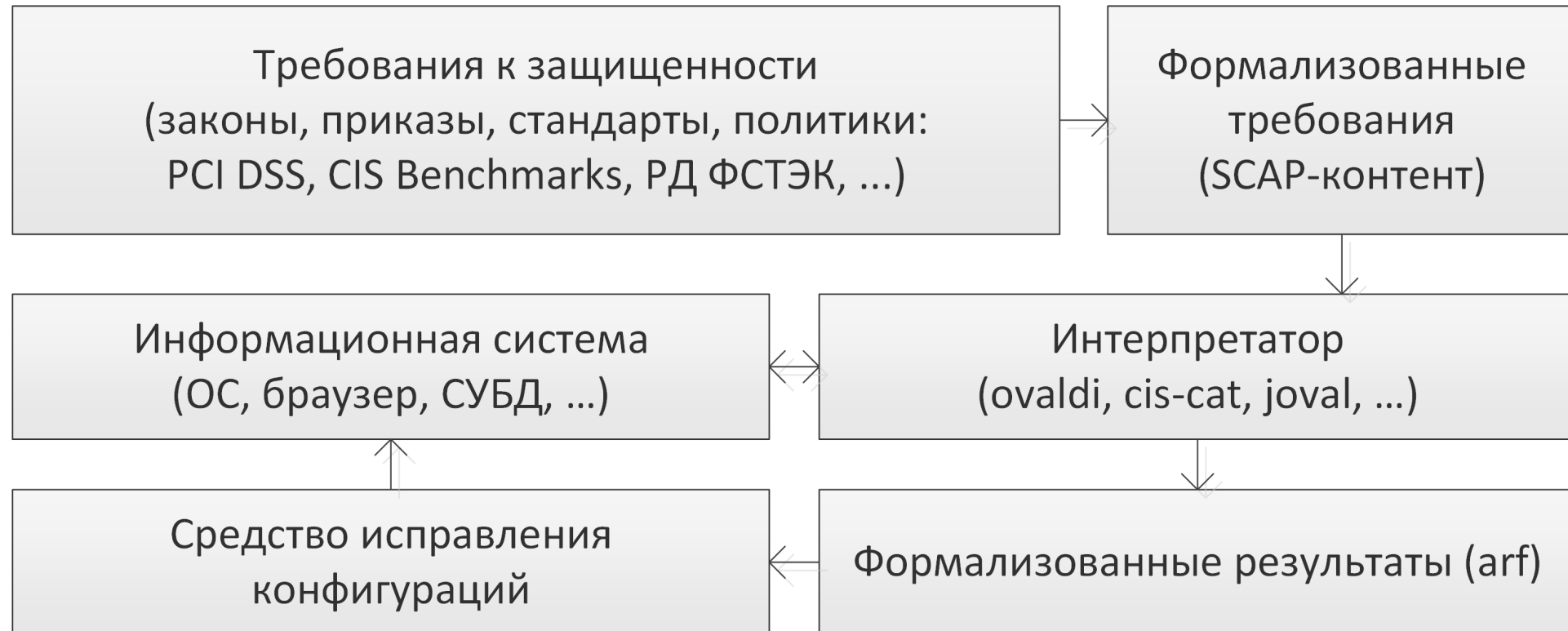
Промыслов Виталий Георгиевич

vitaly.promyslov@gmail.com

Некоторые полезные аббревиатуры

- SCAP Security Content Automation Protocol - протокол автоматизации аудита
- NIST National Institute of Standards and Technology – Национальный центр по стандартам и технологиям (США)
- CPE (англ. Common Platform Enumeration)- Идентификация Платформы
- SWID (англ. Software Identification)- Идентификация Программного обеспечения
- CVE (англ. Common Vulnerabilities and Exposures)- Стандартная номенклатура и словарь по безопасности недостатки программного обеспечения
- CCE (англ. Common Configuration Enumeration)- Идентификация Конфигурации
- CVSS (англ. Common Vulnerability Scoring System)- Стандарт для измерения влияние уязвимостей
- CCSS (англ. Common Configuration Scoring System)- Система оценки конфигурации
- XCCDF (англ. Extensible Configuration Checklist Description Format)- Описания требований ИБ
- OVAL (англ. Open Vulnerability and Assessment Language)-Язык процедур проверки
- CERT Компьютерная группа реагирования на чрезвычайные ситуации
(англ. computer emergency response team)

Структурная схема процесса автоматизированного аудита безопасности информационных систем с использованием SCAP



Процесс управление конфигурацией и обработка уязвимостей

Задачи управление ИБ

- Периодическая проверка конфигураций мер защиты;
- Учет одобренных исключений в конфигурациях;
- Предупреждения о несанкционированных изменениях конфигураций;
- Периодическое выявление уязвимостей.

SCAP определяет три процесса:

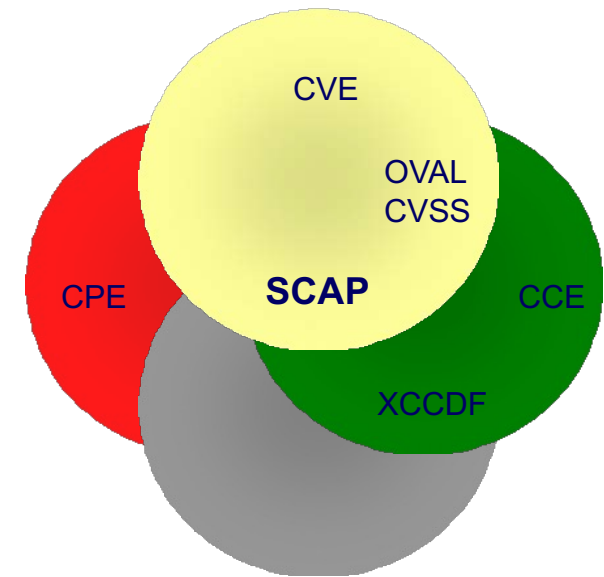
1. Поиск и исправление уязвимостей,
2. Автоматическую проверку и настройку конфигураций,
3. Оценку уровня безопасности.

Компоненты SCAP (Языки XCCDF, OVAL, OCIL, ARF)

- XCCDF (англ. Extensible Configuration Checklist Description Format) — язык, который описывает контрольные списки настроек безопасности и связывает другие компоненты SCAP. XCCDF содержит наборы требований к информационным системам
- OVAL (англ. Open Vulnerability and Assessment Language) — декларативный язык логических утверждений. OVAL описывает уязвимости и необходимое состояние конфигурации информационной системы^ инструкции для интерпретатора, которые эти требования формализуют.
- OCIL (англ. Open Checklist Interactive Language).
- ARF (Asset Reporting Format). Отчет в формате ARF содержится в XML-документе и включает описания профилей, требований из контрольных списков и итоговые результаты по каждому пункту из контрольного списка.

Компоненты SCAP (схемы идентификации)

- Платформы CPE (англ. Common Platform Enumeration);
- Программного обеспечения SWID (англ. Software Identification);
- Уязвимости CVE (англ. Common Vulnerabilities and Exposures);
- Конфигурации CCE (англ. Common Configuration Enumeration).



Компоненты SCAP (метрики)

- CVSS (англ. Common Vulnerability Scoring System)

Базовые метрики 

Внимание! Для получения результата необходимо выбрать значение каждого критерия!

Способ получения доступа (AV):

Локальный (L)	Смежная сеть (A)	Сетевой (N)
---------------	------------------	-------------

Сложность получения доступа (AC):

Высокая (H)	Средняя (M)	Низкая (L)
-------------	-------------	------------

Аутентификация (Au):

Множественная (M)	Единственная (S)	Не требуется (N)
-------------------	------------------	------------------

Влияние на конфиденциальность (C):

Не оказывает (N)	Частичное (P)	Полное (C)
------------------	---------------	------------

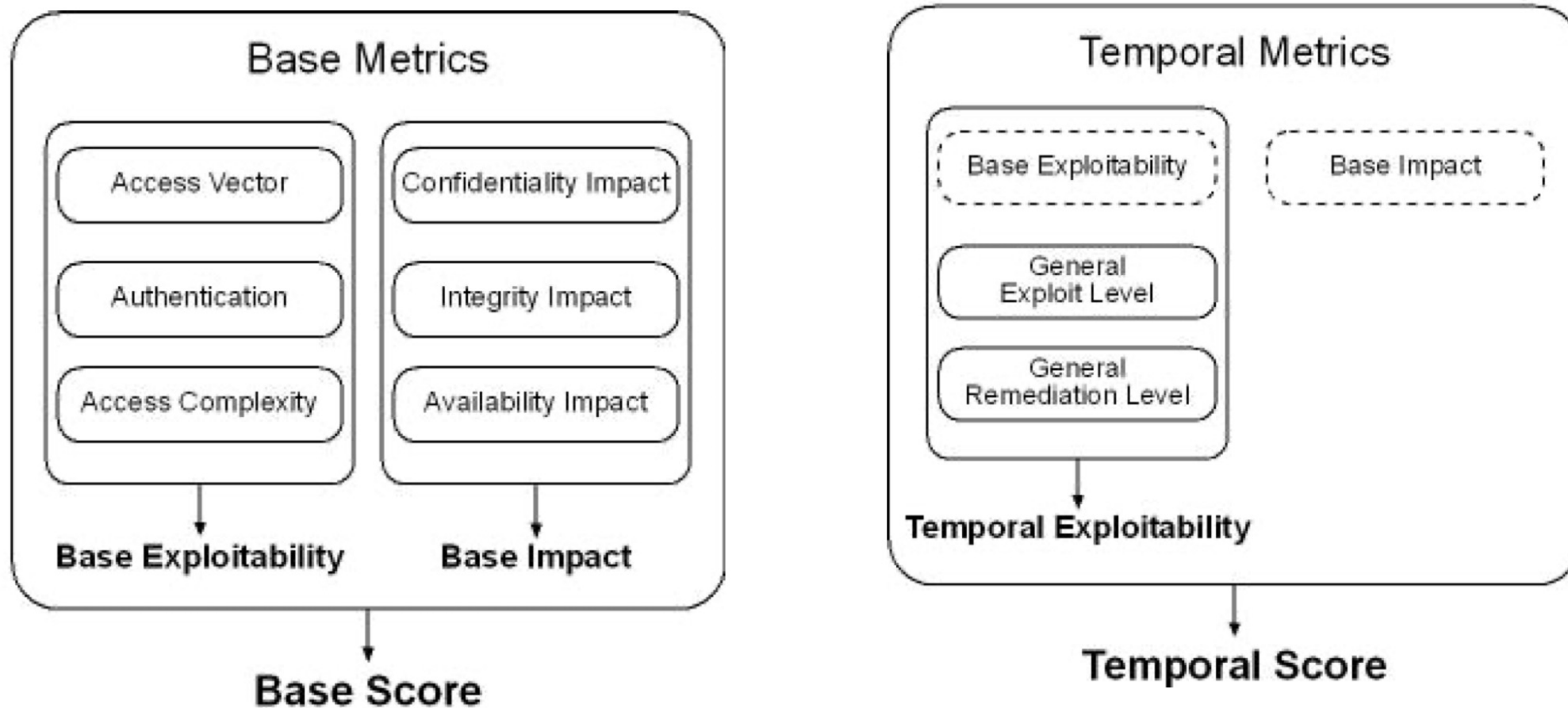
Влияние на целостность (I):

Не оказывает (N)	Частичное (P)	Полное (C)
------------------	---------------	------------

Влияние на доступность (A):

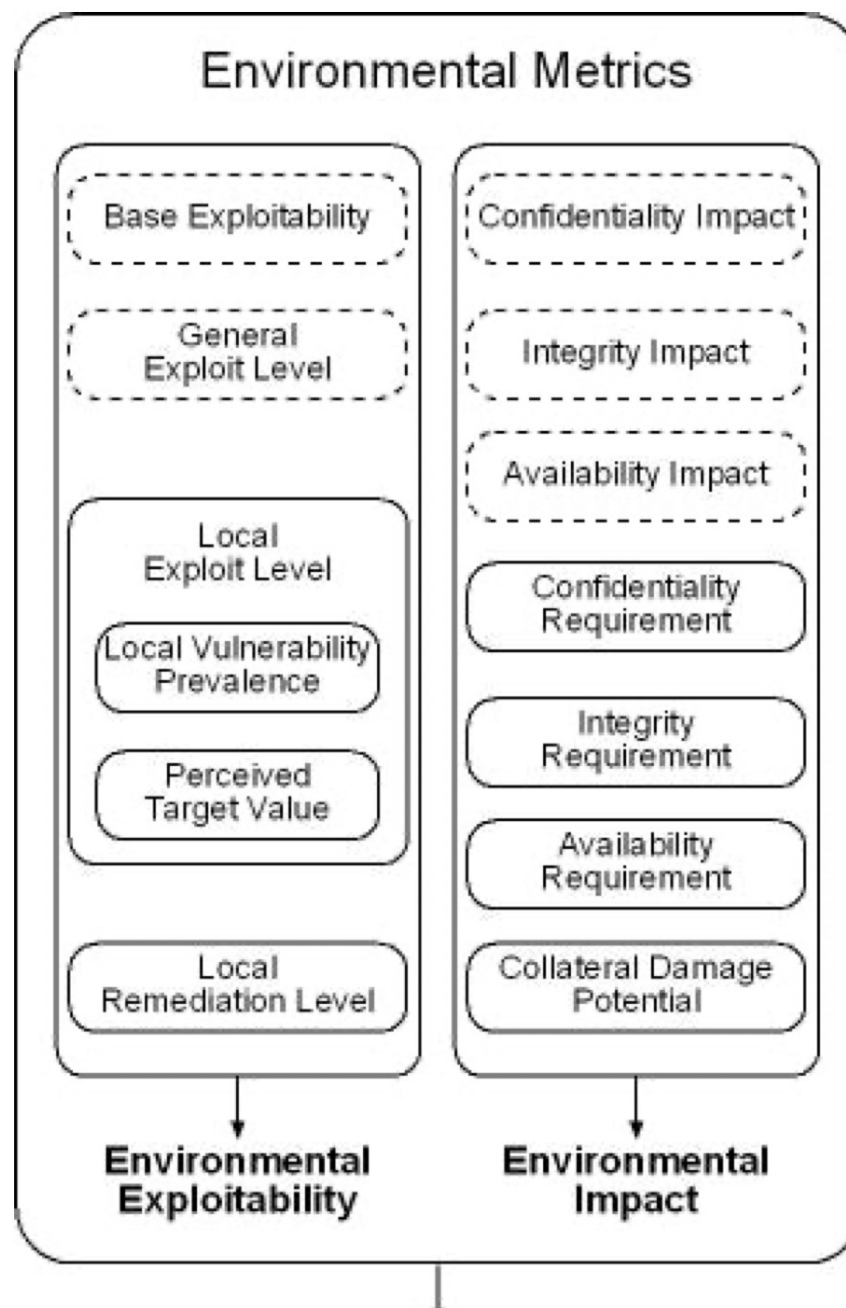
Не оказывает (N)	Частичное (P)	Полное (C)
------------------	---------------	------------

- CCSS (англ. Common Configuration Scoring System)
Общая система оценки конфигурации

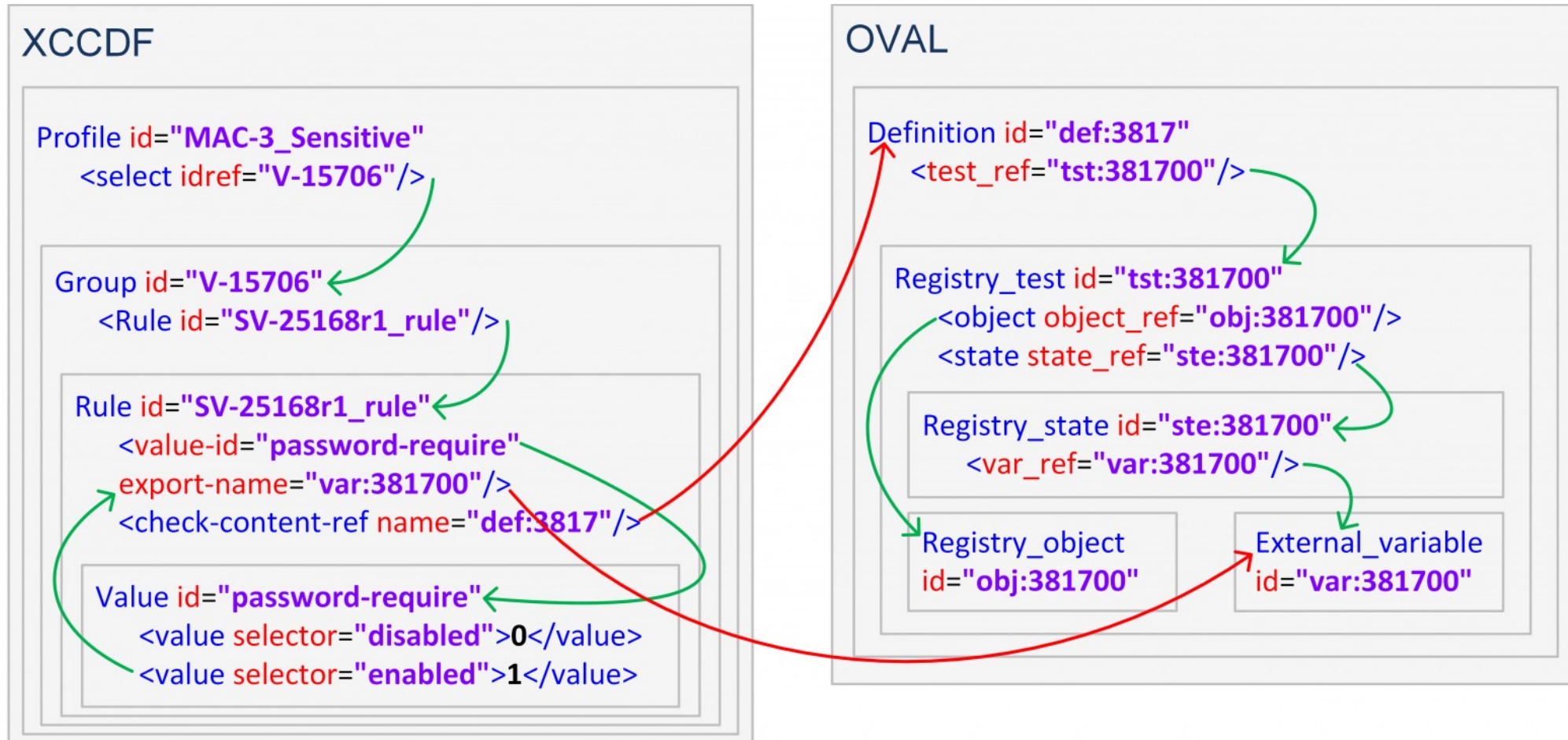


CCSS детали

Компонента метрик, зависящих от того в каком окружении и в какой среде находится оцениваемая система.



Обзор языков спецификация SCAP



XCCDF - eXtensible Configuration Checklist Description Format

- Вида элементов в XCCDF:
- Группы (Group);
- Правила (Rule);
- Значения (Value).



XCDF и связь с исходным документом ИБ

```
<Rule id="SV-25168r1_rule">
```

```
  <title>Password is required on resume from sleep (plugged in).</title>
```

```
  <description>This check verifies that the user is prompted for a password on resume from sleep (Plugged In)</description>
```

```
  <fixtext>Configure the policy value for Computer Configuration - Administrative Templates -> System -> Power Management -> Sleep Settings "Require a Password When a Computer Wakes (Plugged In)" to "Enabled".</fixtext>
```

```
  <check>
```

```
    <check-export value-id="password-require" export-name="var:381700"/>
```

```
    <check-content-ref name="def:3817"/>
```

```
  </check>
```

```
</Rule>
```

OVAL-Open Vulnerability and Assessment Language



Язык описания теста OCIL

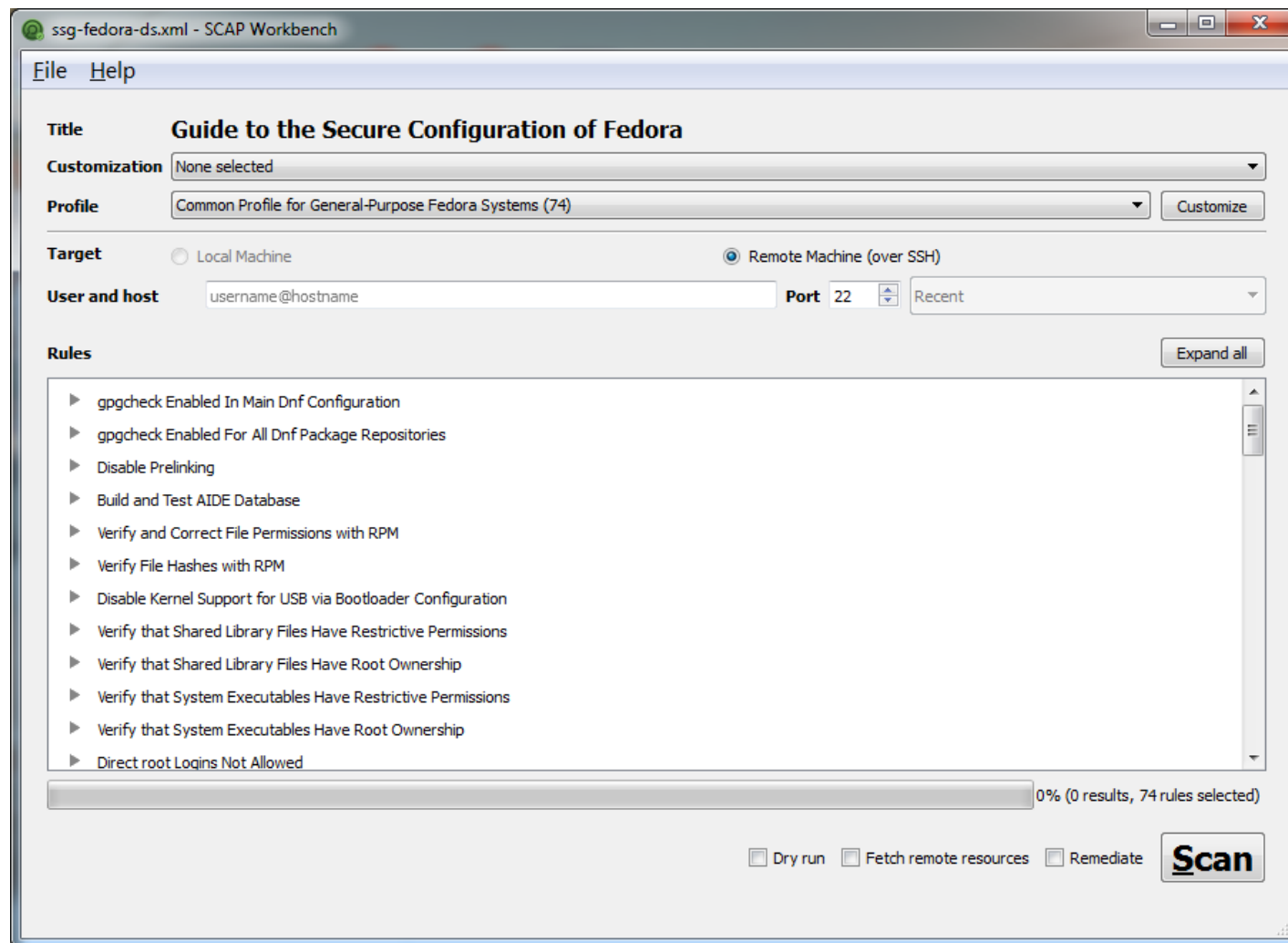
OCIL определяет структуру для выражения набора вопросов, которые должны быть представлены пользователю, и соответствующие процедуры для интерпретации ответов на эти вопросы.

Функции, поддерживаемые OCIL:

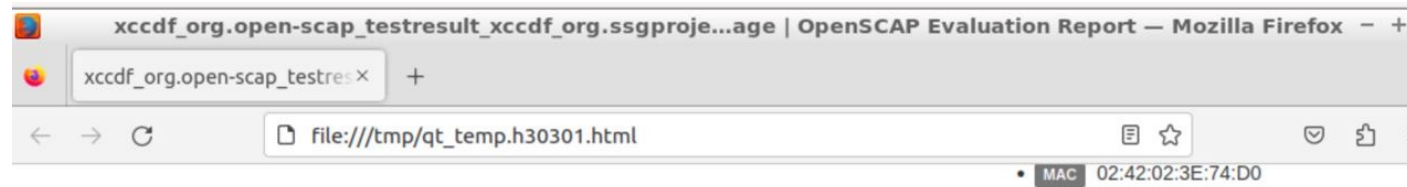
- Возможность определять вопросы (типа Boolean, Choice, Numeric или String);
- Возможность определить возможные ответы на вопрос, из которых пользователь может выбрать;
- Возможность определить действия, которые должны быть предприняты в результате ответа пользователя;
- Возможность перечисления набора результатов.

Интерпретаторы языка SCAP

- OVALdi,
- OpenSCAP
- ScanOVAL
(Программа ScanOVAL для базы данных ФСТЭК доступна с официального сайта).



Пример оценки безопасности для ubuntu 18.04 LTS по профилю ANSSI DAT 28 Average



Compliance and Scoring

The target system did not satisfy the conditions of 15 rules! Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	46.944443	100.000000	46.94%

Rule Overview

- ☒ pass
- ☒ fail
- ☒ notchecked
- ☒ fixed
- ☒ error
- ☒ notapplicable
- ☒ informational
- ☒ unknown

Search through XCCDF rules

Search

Group rules by:

Default

Исправление несоответствий

- Возможности протокола SCAP предполагают автоматическое исправление найденных несоответствий и устранение уязвимостей

5.41 (L1) Ensure 'Xbox Accessory Management Service (XboxGipSvc)' is set to 'Disabled'

Fail

Description:

This service manages connected Xbox Accessories.

The recommended state for this setting is: Disabled.

Rationale:

Xbox Live is a gaming service and has no place in an enterprise environment (perhaps unless it is a gaming company).

Remediation:

To establish the recommended configuration via GP, set the following UI path to: Disabled.

```
Computer Configuration\Policies\Windows Settings\Security Settings\System Services\Xbox Accessory Management Service
```

Impact:

Connected Xbox accessories may not function.

Assessment:

Ensure 'Start' is 'Windows: Registry Value' to '4' -- Less

CIS-CAT expected at least 1 matching registry item to be collected, and found 0 items.

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\XboxGipSvc:Start

does not exist

Проверка уязвимостей

OVAL Results — Mozilla Firefox

OVAL Results x New Tab x xccdf_org.open-scap_testres +

file:///home/vitaly/openscap/oscap_report.html

Interface Name	lo
IP Address	::1
MAC Address	00:00:00:00:00:00
Interface Name	enp1s0
IP Address	fe80::89a0:b94a:c6b2:b23a
MAC Address	52:54:00:1E:82:9A
Interface Name	enp2s0
IP Address	fe80::1b46:8019:e042:378b
MAC Address	52:54:00:F8:B8:E4

OVAL System Characteristics Generator Information

Schema Version	Product Name	Product Version	Date	Time
5.11.1	cpe:/a:open-scap:oscap	1.1	2023-03-17	21:17:43

OVAL Definition Results

Legend: ✗ ✓ Error Unknown Other

ID	Result	Class	Reference ID	Title
oval:com.ubuntu.xenial:def:100	false	inventory		Check that Ubuntu 16.04 LTS (xenial) is installed.
oval:com.ubuntu.xenial:def:2021435190000000	false	vulnerability	[CVE-2021-43519]	CVE-2021-43519 on Ubuntu 16.04 LTS (xenial) - low.
oval:com.ubuntu.xenial:def:2021434000000000	false	vulnerability	[CVE-2021-43400]	CVE-2021-43400 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021433980000000	false	vulnerability	[CVE-2021-43398]	CVE-2021-43398 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021433960000000	false	vulnerability	[CVE-2021-43396]	CVE-2021-43396 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021433890000000	false	vulnerability	[CVE-2021-43389]	CVE-2021-43389 on Ubuntu 16.04 LTS (xenial) - low.
oval:com.ubuntu.xenial:def:2021432670000000	false	vulnerability	[CVE-2021-43267]	CVE-2021-43267 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021430820000000	false	vulnerability	[CVE-2021-43082]	CVE-2021-43082 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021430570000000	false	vulnerability	[CVE-2021-43057]	CVE-2021-43057 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021430560000000	false	vulnerability	[CVE-2021-43056]	CVE-2021-43056 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021429170000000	false	vulnerability	[CVE-2021-42917]	CVE-2021-42917 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021427820000000	false	vulnerability	[CVE-2021-42782]	CVE-2021-42782 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021427810000000	false	vulnerability	[CVE-2021-42781]	CVE-2021-42781 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021427800000000	false	vulnerability	[CVE-2021-42780]	CVE-2021-42780 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021427790000000	false	vulnerability	[CVE-2021-42779]	CVE-2021-42779 on Ubuntu 16.04 LTS (xenial) - medium.
oval:com.ubuntu.xenial:def:2021427780000000	false	vulnerability	[CVE-2021-42778]	CVE-2021-42778 on Ubuntu 16.04 LTS (xenial) - medium.

LXTerminal OVAL Results — Mozilla 22:39

Greenbone and OpenVAS

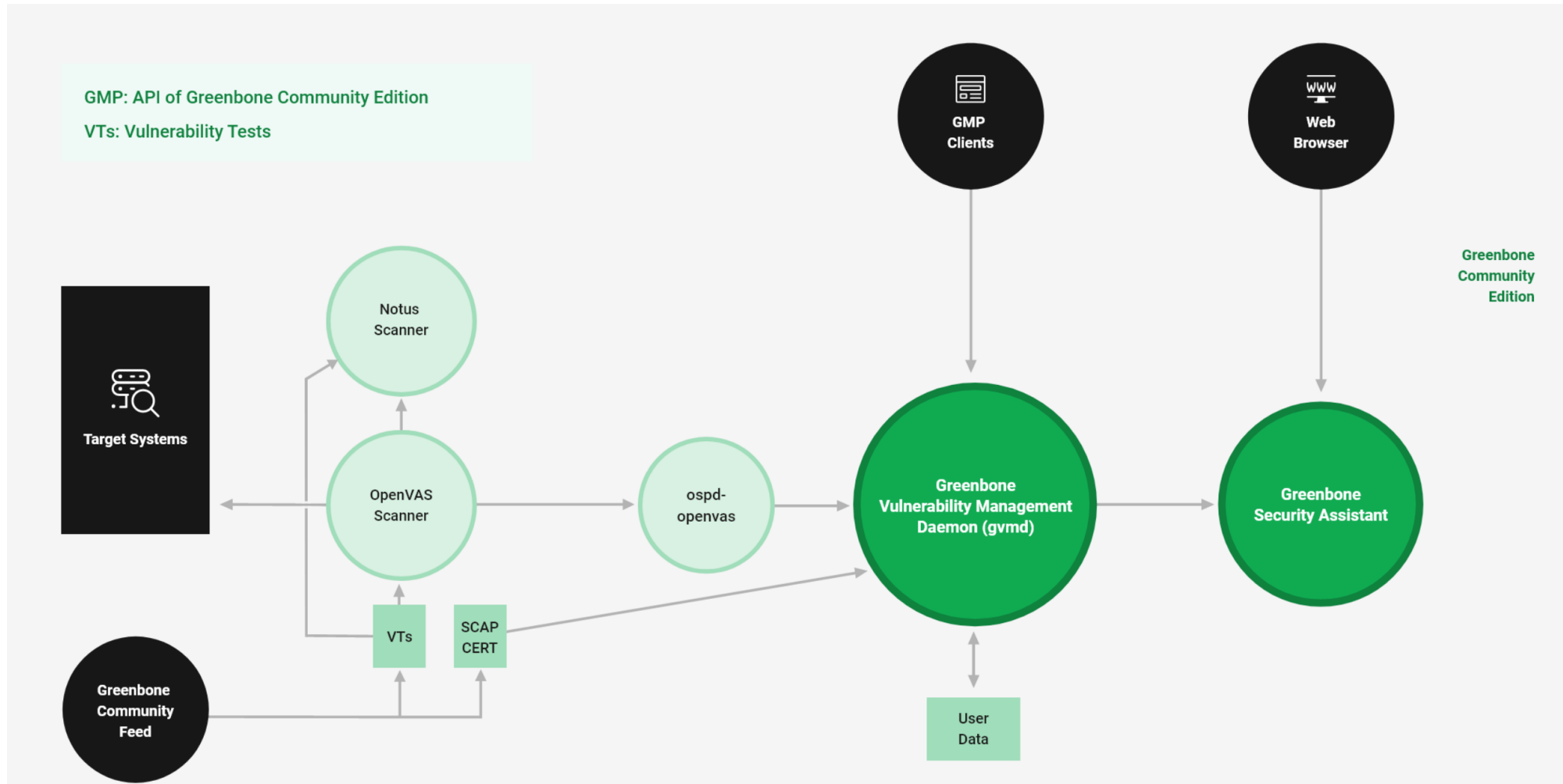


Рис. Архитектура OpenVAS

<https://greenbone.github.io/docs/latest/background.html#history-of-the-openvas-project>